CYBERVSI

Web Application Security Assessment Report

Comprehensive VAPT reporting sample

Document	Public sample
Target	Fictional Customer Portal
Assessment type	Grey-box web application VAPT
Report version	1.0
Report date	10 October 2026
Classification	Public - sample data only

SAMPLE - FICTIONAL DATA

No real client, person, credential, domain, IP address, screenshot, or production evidence appears in this report.

CONNECT@CYBERVSI.COM | SERVICE.CYBERVSI.COM

Document Control

Version	Date	Prepared by	Purpose
1.0	10 October 2026	CyberVSI Security Testing	Public reporting example

Confidentiality and use

This public sample demonstrates CyberVSI's reporting approach. It is not a client deliverable and must not be interpreted as evidence that any named or implied organization was assessed. All technical data is fictional or reserved for documentation.

Contact

CyberVSI
connect@cybervsi.com
https://service.cybervsi.com

Table of Contents

Section	Contents
1	General overview and disclaimer
2	Assessment overview, scope, limitations, and methodology
3	Executive summary, severity model, status model, and risk posture
4	Vulnerability overview
5	Detailed findings WEB-001 through WEB-010
6	Remediation roadmap and retest approach
7	Compliance mapping
8	Appendices and references

1. General Overview

1.1 Purpose

This report communicates the results of a fictional, time-boxed web application security assessment. It separates executive risk context from reproducible technical evidence and provides concrete closure criteria for engineering teams.

1.2 Disclaimer

Security testing provides a point-in-time view based on agreed scope, access, and constraints. No assessment can prove that an application is free of vulnerabilities. Findings should be reassessed after architectural, code, infrastructure, or threat-environment changes.

1.3 Sample-data safeguards

Data class	Treatment
Organization and people	Replaced with CyberVSI or generic role names
Domains	Reserved example.test names
IP addresses	Omitted from this web application sample
Credentials and tokens	Never included; represented by placeholders
Screenshots	Replaced with synthetic text evidence
Dates	Sample publication date only

2. Assessment Overview

2.1 Components

The assessment combines automated discovery with manual validation. Automated results are treated as leads until a tester reproduces the behavior, evaluates preconditions, and confirms impact within the rules of engagement.

Component	Coverage
Vulnerability assessment	Configuration, exposed components, headers, transport controls, and common weakness discovery
Penetration testing	Manual authentication, authorization, session, business-logic, and client-side validation
Risk analysis	CVSS v3.1 base score plus asset and business context
Reporting	Executive summary, technical findings, evidence, remediation, and retest criteria

2.2 Scope

Particular	Sample detail
Application	Fictional Customer Portal
Target	https://portal.example.test
Environment	Non-production assessment environment
Access	Two standard test users and one read-only administrative user
Assessment window	5-9 October 2026
Testing mode	Grey-box, remotely delivered

2.3 Rules, Limitations, and Methodology

Rules of engagement

Testing is authorized only for the listed fictional target and accounts. Stop conditions include service instability, access to out-of-scope records, or instruction from the engagement owner. Evidence collection is minimized and destructive actions are prohibited.

Out of scope

Denial-of-service, social engineering, physical security, persistence, malware, destructive data modification, third-party infrastructure, production customer records, and source-code review.

Methodology

Phase	Activities
Plan	Confirm authorization, targets, accounts, exclusions, contacts, and stop conditions
Discover	Map application functions, technology, roles, and attack surface
Assess	Test authentication, authorization, session, input, business logic, client behavior, and configuration
Validate	Reproduce candidates manually and remove false positives
Analyze	Score technical severity and document business impact assumptions
Report	Provide evidence, remediation, closure criteria, and residual limitations

3. Executive Summary

Overview

The fictional assessment identified 10 findings: 3 High, 4 Medium, 2 Low, and 1 Informational. The highest-priority themes are cross-site request forgery, missing object-level authorization, and insufficient authentication throttling.

Priority actions

1. Enforce server-side authorization for every object and tenant boundary.
2. Correct CSRF design across recovery and claim workflows.
3. Add layered rate limiting, MFA, and authentication monitoring.
4. Revoke sessions after credential changes.
5. Establish dependency and browser security-header baselines.

Finding distribution

Severity	CVSS range	Count	Expected handling
Critical	9.0-10.0	0	Immediate containment
High	7.0-8.9	3	Prioritize before next release
Medium	4.0-6.9	4	Current remediation cycle
Low	0.1-3.9	2	Scheduled hardening
Informational	0.0	1	Defense-in-depth tracking

3.1 Severity, Status, and Posture

Severity model

CVSS v3.1 Base scores express technical severity. CyberVSI keeps the full vector visible so readers can review assumptions. Business priority may change after asset criticality, data sensitivity, threat likelihood, exposure, compensating controls, and regulatory duties are considered.

Status model

Status	Meaning
Open	Validated and awaiting remediation or formal disposition
Resolved	Owner reports a mitigation; independent retest not yet completed
Risk accepted	Authorized owner accepts residual risk with rationale, expiry, and plan
Closed	Retest confirms the root cause is corrected or the finding is demonstrably invalid

Illustrative posture calculation

Metric	Formula / result
Weighted risk	(Critical x 16) + (High x 8) + (Medium x 4) + (Low x 2) = 44
Posture indicator	10 - (weighted risk / 10) = 5.6 / 10
Interpretation	Illustrative only; not a compliance grade or guarantee of security

4. Vulnerability Overview

ID	Finding	OWASP	CVSS	Severity	Status
WEB-001	Cross-site request forgery in account recovery	OWASP A01:2021	8.8	High	Open
WEB-002	Missing authorization on claim update	OWASP A01:2021	8.1	High	Open
WEB-003	Authentication endpoint lacks rate limiting	OWASP A07:2021	7.5	High	Open
WEB-004	Session tokens remain valid after password reset	OWASP A07:2021	5.6	Medium	Open
WEB-005	Outdated client-side components	OWASP A06:2021	6.1	Medium	Open
WEB-006	Anti-CSRF token accepted outside intended context	OWASP A01:2021	5.4	Medium	Open
WEB-007	Application can be framed by untrusted origins	OWASP A05:2021	4.3	Medium	Open
WEB-008	Content Security Policy is not enforced	OWASP A05:2021	3.1	Low	Open
WEB-009	HSTS header is missing	OWASP A02:2021	3.1	Low	Open
WEB-010	Verbose server identification	OWASP A05:2021	0.0	Informational	Open

Positive observations

The sample assumes TLS certificate validation succeeds, generic authentication errors do not disclose account existence, server-side input validation is present for tested fields, and no confirmed SQL injection, stored cross-site scripting, or server-side request forgery was identified within the fictional scope.

Coverage note: No finding means no weakness was confirmed within the agreed sample tests and constraints; it does not guarantee that the application is free of vulnerabilities.

WEB-001 - Cross-site request forgery in account recovery

HIGH	CVSS 3.1 8.8	Open	WEB-001

Field	Value
Affected asset	https://portal.example.test/account/recovery
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Classification	CWE-352 | OWASP A01:2021 | WSTG-SESS-05
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

The account-recovery completion request accepts a state-changing cross-site request without validating an unpredictable anti-CSRF token or trusted request origin.

Business impact

A user who follows an attacker-controlled link while completing recovery could have the recovery action altered, potentially resulting in account compromise and unauthorized access to sensitive records.

Steps to reproduce

1. Start account recovery for the approved fictional user.
2. Capture the completion request in an intercepting proxy.
3. Remove the anti-CSRF value and change Origin to an untrusted site.
4. Replay the request and observe that the server accepts it.

SANITIZED EVIDENCE

```
POST /account/recovery/complete HTTP/1.1
Host: portal.example.test
Origin: https://attacker.example
csrf_token:
Result: HTTP/1.1 200 OK (sample response)
```

Recommended remediation

Require a cryptographically strong, session-bound anti-CSRF token for every state-changing request. Validate Origin or Referer as a secondary control, use SameSite cookies, and invalidate recovery tokens immediately after use.

Retest and closure criteria

The request is rejected when the CSRF token is missing, invalid, reused, or submitted from an untrusted origin. Valid same-origin recovery remains functional.

WEB-002 - Missing authorization on claim update

HIGH	CVSS 3.1 8.1	Open	WEB-002

Field	Value
Affected asset	https://portal.example.test/api/claims/{claimId}
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Classification	CWE-639 | OWASP A01:2021 | WSTG-ATHZ-04
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

The claim update endpoint authenticates the caller but does not verify that the referenced claim belongs to the caller's tenant before returning and modifying data.

Business impact

A standard authenticated user could view or alter another tenant's claim record, exposing personal and financial data and undermining record integrity.

Steps to reproduce

1. Sign in as tenant-alpha.example.test.
2. Capture an update to an owned claim.
3. Replace the claim identifier with the approved tenant-beta test record.
4. Observe a successful response and modified test data.

SANITIZED EVIDENCE

```
PATCH /api/claims/CLM-2042 HTTP/1.1
Authorization: Bearer
{"status":"reviewed"}
Result: HTTP/1.1 200 OK (fictional record)
```

Recommended remediation

Enforce object ownership in the service layer for every read and update. Resolve tenant identity from the trusted session, deny cross-tenant identifiers consistently, and add negative authorization tests for sibling endpoints.

Retest and closure criteria

Cross-tenant claim reads and writes return an authorization error, while same-tenant operations continue to work.

WEB-003 - Authentication endpoint lacks rate limiting

HIGH	CVSS 3.1 7.5	Open	WEB-003

Field	Value
Affected asset	https://portal.example.test/api/auth/login
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Classification	CWE-307 | OWASP A07:2021 | WSTG-ATHN-03
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

Repeated failed authentication attempts are processed without account, source, or device-based throttling. Responses remain consistent after the approved test threshold.

Business impact

Attackers could automate password guessing or credential stuffing, increasing the likelihood of account compromise where credentials are weak or reused.

Steps to reproduce

1. Submit an invalid password for the approved test account.
2. Repeat within the agreed safe request threshold.
3. Compare status codes, response times, and rate-limit headers.
4. Confirm no progressive delay, temporary block, or alert is triggered.

SANITIZED EVIDENCE

```
Approved test: 25 invalid attempts in 60 seconds
Observed responses: 25 x HTTP 401
Retry-After header: absent
Lockout or progressive delay: not observed
```

Recommended remediation

Apply layered throttling by account and source, introduce progressive delays, detect credential stuffing, require MFA for sensitive access, and alert on anomalous authentication patterns. Avoid permanent denial-of-service through account lockout.

Retest and closure criteria

The endpoint throttles repeated attempts, returns a safe generic response, logs the event, and allows legitimate recovery without revealing account validity.

WEB-004 - Session tokens remain valid after password reset

MEDIUM	CVSS 3.1 5.6	Open	WEB-004

Field	Value
Affected asset	Portal session and refresh-token services
CVSS vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N
Classification	CWE-613 | OWASP A07:2021 | WSTG-SESS-06
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

Changing or resetting a password does not revoke previously issued web sessions and refresh tokens.

Business impact

A stolen session could remain usable after the account owner attempts recovery, extending unauthorized access.

Steps to reproduce

1. Create two sessions for the same fictional account.
2. Reset the password from Session A.
3. Replay Session B after the reset completes.
4. Observe that the existing session remains valid.

SANITIZED EVIDENCE

```
Session A: password reset completed
Session B: issued before reset
GET /api/profile with Session B after reset
Result: HTTP/1.1 200 OK
```

Recommended remediation

Revoke active sessions and refresh tokens after credential changes. Rotate the current session, require reauthentication for sensitive actions, and provide users with session-management controls.

Retest and closure criteria

All pre-reset sessions are rejected and only a newly authenticated session can access protected resources.

WEB-005 - Outdated client-side components

MEDIUM	CVSS 3.1 6.1	Open	WEB-005

Field	Value
Affected asset	Public web bundles on portal.example.test
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Classification	CWE-1104 | OWASP A06:2021 | WSTG-CONF-05
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

The application includes unsupported client-side library versions with publicly documented security issues. Exploitability depends on whether affected functions are reachable in the application context.

Business impact

A reachable vulnerable code path could enable client-side code execution or content manipulation in a user's browser.

Steps to reproduce

1. Review loaded JavaScript and stylesheet resources.
2. Identify component names and versions from package metadata or source maps.
3. Compare versions with vendor advisories.
4. Manually validate whether affected functionality is reachable.

SANITIZED EVIDENCE

```
Sample inventory:
jquery 2.x - unsupported branch
bootstrap 3.x - legacy branch
Exact production versions and hashes intentionally omitted
```

Recommended remediation

Upgrade to supported stable releases, remove unused libraries, maintain a software bill of materials, enable dependency scanning in CI, and verify the upgrade with regression and security tests.

Retest and closure criteria

The deployed bundle contains supported versions and dependency scanning reports no unresolved applicable advisories.

WEB-006 - Anti-CSRF token accepted outside intended context

MEDIUM	CVSS 3.1 5.4	Open	WEB-006

Field	Value
Affected asset	Claim creation and update workflows
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N
Classification	CWE-352 | OWASP A01:2021 | WSTG-SESS-05
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

The application accepts an anti-CSRF token that is not tightly bound to the active session and action, reducing the control's resistance to token reuse.

Business impact

Under specific preconditions, a captured token could be reused to support unauthorized state-changing requests.

Steps to reproduce

1. Capture a token from the approved first session.
2. Create a second session for the same fictional user.
3. Submit the first token with a state-changing request in the second session.
4. Observe the request is accepted.

SANITIZED EVIDENCE

```
Token from Session A replayed with approved Session B
Endpoint: POST /api/claims/update
Result: request accepted in sample test context
```

Recommended remediation

Bind tokens to the authenticated session and intended action, use sufficient entropy, validate tokens server-side, prevent reuse where practical, and combine with SameSite cookies and origin validation.

Retest and closure criteria

Tokens copied across sessions or actions are rejected without changing application state.

WEB-007 - Application can be framed by untrusted origins

MEDIUM	CVSS 3.1 4.3	Open	WEB-007

Field	Value
Affected asset	Authenticated portal pages
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Classification	CWE-1021 | OWASP A05:2021 | WSTG-CLNT-09
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

Responses do not restrict embedding through CSP frame-ancestors or X-Frame-Options, allowing the portal to be displayed in an attacker-controlled frame.

Business impact

An attacker could attempt UI redressing to induce unintended clicks. Impact depends on the sensitivity of actions that can be completed without reauthentication or confirmation.

Steps to reproduce

1. Create a local HTML page containing an iframe for the fictional portal.
2. Open the page in a supported browser.
3. Confirm the portal renders within the frame.
4. Do not perform a real transaction.

SANITIZED EVIDENCE

```
Content-Security-Policy frame-ancestors: absent
X-Frame-Options: absent
Sample iframe load result: rendered successfully
```

Recommended remediation

Set Content-Security-Policy: frame-ancestors 'none' or explicitly list trusted origins. Retain anti-CSRF controls and require confirmation for sensitive actions.

Retest and closure criteria

Untrusted framing is blocked by the browser while any documented trusted integration continues to work.

WEB-008 - Content Security Policy is not enforced

LOW	CVSS 3.1 3.1	Open	WEB-008

Field	Value
Affected asset	Public and authenticated web responses
CVSS vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Classification	CWE-693 | OWASP A05:2021 | WSTG-CONF-12
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

The application does not send an enforcing Content-Security-Policy header. CSP is a defense-in-depth control and its absence does not by itself demonstrate script injection.

Business impact

A future injection defect may have greater impact because the browser is not instructed to restrict script, frame, and resource origins.

Steps to reproduce

1. Request representative public and authenticated pages.
2. Review response headers.
3. Confirm that no enforcing CSP is present.
4. Document required resource origins before rollout.

SANITIZED EVIDENCE

```
GET /dashboard HTTP/1.1
Response headers reviewed
Content-Security-Policy: absent
Content-Security-Policy-Report-Only: absent
```

Recommended remediation

Develop a restrictive policy using nonces or hashes, deploy in Report-Only mode, review violations, then enforce it. Avoid broad wildcards and unsafe-inline where possible.

Retest and closure criteria

Representative pages return an enforcing policy and function without unexpected blocked resources.

WEB-009 - HSTS header is missing

LOW	CVSS 3.1 3.1	Open	WEB-009

Field	Value
Affected asset	HTTPS responses on portal.example.test
CVSS vector	CVSS:3.1/AV:A/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Classification	CWE-319 | OWASP A02:2021 | WSTG-CRYP-03
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

HTTPS responses do not include Strict-Transport-Security, so browsers are not instructed to require HTTPS for future connections.

Business impact

A suitably positioned attacker may attempt an initial-connection downgrade where users can reach the service over an insecure path.

Steps to reproduce

1. Request the portal over HTTPS.
2. Inspect response headers from representative routes.
3. Confirm HSTS is absent.
4. Verify all subdomains are HTTPS-ready before recommending includeSubDomains.

SANITIZED EVIDENCE

```
HTTP/1.1 200 OK
Strict-Transport-Security: absent
TLS certificate validation: successful
```

Recommended remediation

After confirming complete HTTPS coverage, add Strict-Transport-Security with an appropriate max-age. Introduce includeSubDomains and preload only after operational review.

Retest and closure criteria

HTTPS responses include the approved HSTS policy and HTTP requests redirect safely to HTTPS.

WEB-010 - Verbose server identification

INFORMATIONAL	CVSS 3.1 0.0	Open	WEB-010

Field	Value
Affected asset	HTTP response headers and error pages
CVSS vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:N
Classification	CWE-200 | OWASP A05:2021 | WSTG-INFO-08
Evidence handling	Synthetic and sanitized; no client data or live credentials

Description

Responses reveal product and framework information that can assist technology fingerprinting.

Business impact

The information does not directly provide access, but it can help an attacker focus reconnaissance and research applicable weaknesses.

Steps to reproduce

1. Request a valid page and an approved nonexistent route.
2. Review response headers and error content.
3. Record unnecessary product identifiers.
4. Do not infer patch status from the banner alone.

SANITIZED EVIDENCE

```
Server: example-gateway/1.x
X-Powered-By: ExampleFramework
Values are fictional and sanitized
```

Recommended remediation

Remove unnecessary version and framework headers, use generic error pages, keep software supported and patched, and avoid treating banner suppression as a substitute for remediation.

Retest and closure criteria

External responses no longer disclose unnecessary product or version details.

6. Remediation Roadmap

Timeframe	Actions	Primary owner
0-7 days	Restrict vulnerable recovery flow, enforce object ownership, introduce emergency authentication throttling, and expand monitoring	Application owner and security
8-30 days	Complete durable CSRF, authorization, session-revocation, and rate-limit fixes; add automated negative tests	Engineering
31-60 days	Upgrade dependencies, enforce browser security headers, complete retest, and retain closure evidence	Engineering and governance
Ongoing	Integrate SAST, DAST, dependency analysis, secrets scanning, threat modeling, and periodic VAPT into the SDLC	Security leadership

Retest approach

CyberVSI retests the original proof, verifies the underlying control across equivalent endpoints, checks for regressions, and records objective closure evidence. A mitigation should not be marked Closed solely from a screenshot or owner statement when safe independent validation is possible.

7. Compliance Mapping

Finding group	OWASP Top 10	SOC 2 examples	ISO/IEC 27001:2022 examples
Authorization and CSRF	A01 Broken Access Control	CC6.1, CC6.3	A.5.15, A.8.3, A.8.4
Authentication and sessions	A07 Identification and Authentication Failures	CC6.1, CC6.2	A.5.16, A.5.17, A.8.5
Outdated components	A06 Vulnerable and Outdated Components	CC7.1, CC7.2, CC8.1	A.8.8, A.8.9, A.8.32
Security headers and disclosure	A02/A05 Cryptographic Failures and Misconfiguration	CC6.6, CC7.1	A.8.9, A.8.20, A.8.26

Mapping disclaimer

Framework mapping supports triage and audit discussion but does not establish compliance. Applicability and evidence requirements must be validated by the organization's control owners and auditors.

8. Appendices

8.1 References

OWASP Web Security Testing Guide v4.2 - https://wstg.owasp.org/v4.2/
OWASP Top 10:2021 - https://owasp.org/Top10/
FIRST CVSS v3.1 - https://www.first.org/cvss/v3.1/specification-document
NIST SP 800-115 - https://doi.org/10.6028/NIST.SP.800-115
CWE - https://cwe.mitre.org/

8.2 Evidence conventions

Tokens, credentials, personal data, internal identifiers, and implementation details are redacted. Real reports may include screenshots or request excerpts only when necessary to reproduce the issue and authorized for inclusion.

8.3 Final sample notice

Every organization name, person, account, endpoint, response, score context, date, and observation in this document is fictional or reserved for documentation. This sample is intended to show format and depth, not to describe a real assessment.

CYBERVSI
Practical security testing. Clear remediation.
connect@cybervsi.com